

Security+ 2.4 · On-path Attacks

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — On-path Attacks (5:30)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: On-path (antigo man-in-the-middle): atacante fica no MEIO da comunicação e INTERCEPTA ou ALTERA o tráfego. ARP spoofing (mentira no MAC table local — o tráfego passa pelo atacante); evil twin AP; DNS poisoning. Defesa: TLS em tudo (o S importa), VPN em rede pública, ARP inspection.

Highlights que a prova cobra

- On-path (antes MITM): intercepta e/ou altera comunicação
- ARP spoofing: mentira o MAC — redireciona tráfego ao atacante
- Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)

Dicas de prova & Cenários Típicos

- 'traffic intercepted between two parties' = on-path/MITM

Cenário clássico de exame: Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra outra máquina' = ARP spoofing (a base de on-path).

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — On-path Attacks)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **MAC:** Mandatory Access Control: Modelo rígido de controle de acesso governamental/militar baseado em etiquetas de segurança (Top Secret, Secret, Unclassified) atribuídas por autoridade central.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:

- A) Ataque on-path (MITM)
- B) Negação de serviço
- C) SQL injection
- D) Força bruta

2. Qual tipo de ataque explora vulnerabilidades antes que um patch esteja disponível?

- A) Ataque de dia zero (Zero-day)
- B) Ataque DDoS
- C) Ataque de força bruta
- D) Ataque Man-in-the-Middle

3. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'On-path (antes MITM): intercepta e/ou altera comunicação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'ARP spoofing: mentira o MAC — redireciona tráfego ao atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'traffic intercepted between two parties' = on-path/MITM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'traffic intercepted between two parties' = on-path/MITM...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra outra máquina' = ARP spoofing (a base de on-path)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra out...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'On-path (antes MITM): intercepta e/ou altera comunicação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'ARP spoofing: mentira o MAC — redireciona tráfego ao atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante...

10. Cenário corporativo (On-path Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Ataque on-path (MITM).

✓ **Por que está certa:** A alternativa correta é 'Ataque on-path (MITM)'. O ataque on-path, também conhecido como man-in-the-middle (MITM), ocorre quando um atacante se posiciona secretamente entre duas partes que acreditam estar se comunicando diretamente. O atacante pode interceptar, alterar ou retransmitir mensagens sem que as partes percebam. O enunciado descreve exatamente esse cenário: o atacante se posiciona entre duas partes e intercepta/altera a comunicação. A CompTIA utiliza o termo 'on-path attack' como sinônimo de MITM, sendo a resposta precisa para a descrição.

✗ **Por que as outras estão erradas:**

- *Negação de serviço:* Negação de serviço (DoS) é um ataque que visa tornar um serviço, rede ou sistema indisponível para usuários legítimos, geralmente sobrecarregando-o com tráfego malicioso. Não envolve interceptação ou alteração de comunicação entre duas partes. O objetivo é interromper o serviço, não espionar ou modificar dados. Portanto, DoS não se aplica ao cenário descrito.
- *SQL injection:* SQL injection é uma técnica de ataque que explora vulnerabilidades em aplicações web que não validam adequadamente as entradas do usuário, permitindo a execução de comandos SQL maliciosos no banco de dados. Não tem relação com interceptação de comunicação entre duas partes. É um ataque de injeção, não de posicionamento intermediário. Portanto, SQL injection está incorreto.
- *Força bruta:* Força bruta é um método de ataque que consiste em tentar exaustivamente todas as combinações possíveis de senhas ou chaves para obter acesso não autorizado. Não envolve interceptação ou alteração de tráfego. É um ataque de adivinhação, não de posicionamento entre partes. Portanto, força bruta não é a resposta correta.

2) A — Ataque de dia zero (Zero-day).

✓ **Por que está certa:** A alternativa correta é 'Ataque de dia zero (Zero-day)'. Um ataque de dia zero explora uma vulnerabilidade que é desconhecida do fornecedor do software ou hardware, ou para a qual ainda não existe patch disponível. O termo 'dia zero' refere-se ao fato de que a exploração ocorre antes que o desenvolvedor tenha tido a oportunidade de corrigir a falha, ou no mesmo dia em que a vulnerabilidade se torna conhecida. Esses ataques são particularmente perigosos porque não podem ser mitigados por assinaturas de antivírus ou correções tradicionais, exigindo defesas proativas como análise comportamental, sandboxing e segmentação de rede. No CompTIA Security+, o conceito de zero-day é associado a ameaças avançadas e à necessidade de estratégias de defesa em profundidade.

✗ **Por que as outras estão erradas:**

- *Ataque DDoS:* Um ataque DDoS (Distributed Denial of Service) tem como objetivo sobrecarregar um serviço, servidor ou rede com tráfego massivo proveniente de múltiplas fontes, tornando-o indisponível para usuários legítimos. Ele não explora uma vulnerabilidade específica de software para a qual não há patch; em vez disso, abusa da capacidade de recursos e largura de banda. Embora possa ser devastador, o DDoS não se enquadra na definição de ataque de dia zero, pois não depende de uma falha desconhecida e não corrigida. A mitigação envolve filtragem de tráfego, CDNs e serviços anti-DDoS, e não a aplicação de patches.
- *Ataque de força bruta:* Um ataque de força bruta tenta adivinhar credenciais (senhas, chaves) por meio de tentativas exaustivas e repetidas, muitas vezes automatizadas. Ele explora a fraqueza de senhas curtas ou previsíveis, não uma vulnerabilidade de software sem correção. Embora possa ser usado para obter acesso inicial, não é classificado como ataque de dia zero. As defesas incluem

políticas de senha forte, bloqueio de conta, autenticação multifator e limitação de taxa, e não dependem de um patch específico para uma falha desconhecida.

• *Ataque Man-in-the-Middle*: Um ataque Man-in-the-Middle (MitM) ocorre quando um adversário se posiciona entre duas partes que se comunicam, interceptando e possivelmente alterando o tráfego. Ele explora falhas de autenticação, criptografia fraca ou configurações inseguras (ex.: ARP spoofing, DNS spoofing), mas não é definido pela exploração de uma vulnerabilidade sem patch. O MitM pode ser mitigado com criptografia forte, certificados digitais e autenticação mútua. Não se confunde com zero-day, que se refere especificamente a uma vulnerabilidade desconhecida e não corrigida.

3) B — Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): On-path (antes MITM): intercepta e/ou altera comunicação.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): ARP spoofing: mentira o MAC — redireciona tráfego ao atacante.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Defesa nº1: HTTPS em tudo (o TLS autentica o endpoint).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'traffic intercepted between two parties' = on-path/MITM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): 'traffic intercepted between two parties' = on-path/MITM.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra out....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Cenário: 'computador dentro da rede recebe o tráfego que deveria ir pra outra máquina' = ARP spoofing (a base de on-path)..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: On-path (antes MITM): intercepta e/ou altera comunicação....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): On-path (antes MITM): intercepta e/ou altera comunicação.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: ARP spoofing: mentira o MAC — redireciona tráfego ao atacante....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): ARP spoofing: mentira o MAC — redireciona tráfego ao atacante.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (On-path Attacks): Defesa nº1: HTTPS em tudo (o TLS autêntica o endpoint).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.